

Модуль D "Цифровая криминалистика". Сетевой дамп

Executive Summary

Высокоуровневое описание инцидента. Здесь представлена информация, которая представляет наибольшую важность для исполнительных руководителей компании без указания конкретных технических подробностей. Данный раздел должен содержать:

- 1. Временные рамки инцидента
- 2. Вектор(а) атаки
- 3. Высокоуровневое описание последовательности атаки
- 4. ВПО и инструменты, которые были использованы в процессе атаки (без конкретного описания технических деталей)
- 5. Какие цели были поставлены злоумышленниками и какие результаты были достигнуты при атаке

Объекты исследования

Название объекта исследования	Описание объекта исследования
trtraffic.pcapng	Дамп сетевого трафика Wireshark

Результаты исследования

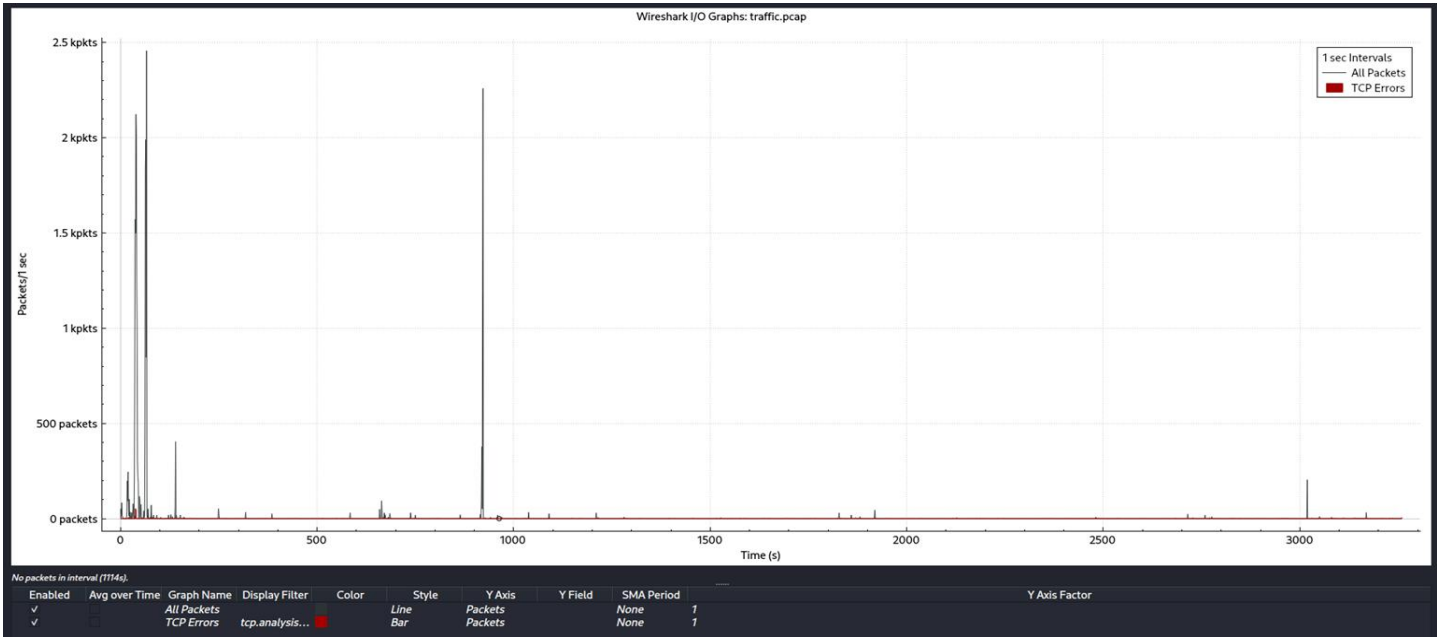
Данный раздел содержит технические детали инцидента.

Временные рамки инцидента

В таблице данного раздела участникам необходимо привести конкретные события на скомпрометированных системах.

Дата и время события	Краткое описание
Дата инцидента: 26 ноября 2024 года Время начала: 07:49:38 по московскому времени (04:49:38 UTC) Часовой пояс: UTC+3 (Москва)	Перехваченный дамп трафика

Статистика активности с дампа



Вектор атаки и подтверждающая информация

Атака была произведена с использованием скомпрометированной рабочей станции DESKTOP-B8TQK49 (10.11.26.183) против доменного контроллера NEMOTODES-DC (10.11.26.3). Злоумышленник использовал валидные учетные данные пользователя oboomwald для проведения разведки доменной инфраструктуры через протоколы Kerberos, LDAP и SAMR.

Сутью атаки является злоупотребление легитимными доменными механизмами для сбора конфиденциальной информации и последующей массовой эксфильтрации данных через multiple зашифрованные TLS-каналы на внешние серверы. Возможно, злоумышленник использовал технику "Traffic Blending", смешивая вредоносную активность с легитимным веб-трафиком к Google и Microsoft сервисам. Также используются уязвимости http для отправки подозрительных запросов формата base64. Трафик идет в незашифрованном виде на порт 443. Далее происходит скачивание возможно нескольких файлов. После чего производились Регулярные heartbeat-сообщения каждые 60 секунд HTTP POST на порт 443 к /fakeurl.htm. Были получены некие данные.

Подтверждающие доказательства

Фрейм 235: TGS-REP с CNameString: oboomwald - успешная Kerberos-аутентификация

Фреймы 330-381: Серия SAMR-запросов (Connect5, EnumDomains, QueryUserInfo, GetGroupsForUser) к доменному контроллеру

Фреймы 21337, 21352, 21364: Периодические HTTP POST запросы к http://194.180.191.64/fakeurl.htm на порту 443

Фреймы 1184-22395: Массовая TLS-экфильтрация данных на внешние серверы 213.246.109.5, 193.42.38.139, 173.222.49.101

Описание последовательности атаки

Этап 1

Через некоторое время произошла Kerberos-аутентификация, затем выполнились SAMR-запросы на перечисление пользователей и групп. Перед этим возможно совершались LDAP-запросы для обнаружения структуры домена.

LDAP-запросы: Обнаружение структуры домена

13	0.460460	10.11.26.183	10.11.26.3	DNS	118	Standard query 0x3b4c SRV _ldap._tcp.Default-First-Site-Name._sites.nemotoads.health
14	0.460524	10.11.26.183	10.11.26.3	DNS	118	Standard query 0x0fe3 SRV _ldap._tcp.Default-First-Site-Name._sites.nemotoads.health
17	0.460925	10.11.26.3	10.11.26.183	DNS	183	Standard query response 0x0fe3 SRV _ldap._tcp.Default-First-Site-Name._sites.nemotoads.health SRV 0 100 389 nemotodes-dc.nemotoads.health A 10.11.26.3

36	0.571250	10.11.26.183	10.11.26.3	LDAP	404	searchRequest(12) "<ROOT>" baseObject
40	0.572715	10.11.26.3	10.11.26.183	LDAP	1393	searchResEntry(12) "<ROOT>" searchResDone(12) success [1 result]

Kerberos-аутентификация: Получение TGS-билетов

214	16.965965	10.11.26.3	10.11.26.183	KRB5 245	KRB Error
223	16.972980	10.11.26.3	10.11.26.183	KRB5 340	AS-REP
232	16.973914	10.11.26.183	10.11.26.3	KRB5 254	TGS-REQ
235	16.976443	10.11.26.3	10.11.26.183	KRB5 275	TGS-REP

```
Frame 235: Packet, 275 bytes on wire (2200 bits), 275 bytes captured (2200 bits) on interface 0
Ethernet II, Src: Dell_7f:09:5d (00:24:e8:7f:09:5d), Dst: Intel_ce:fc:8b (d0:57:7b:ce:fc:8b)
Internet Protocol Version 4, Src: 10.11.26.3, Dst: 10.11.26.183
Transmission Control Protocol, Src Port: 88, Dst Port: 53288, Seq: 1461, Ack: 1661, Len: 221
  Source Port: 88
  Destination Port: 53288
  [Stream index: 8]
  [Stream Packet Number: 8]
  [Conversation completeness: Complete, WITH_DATA (63)]
  [TCP Segment Len: 221]
  Sequence Number: 1461 (relative sequence number)
  Sequence Number (raw): 3861193133
  [Next Sequence Number: 1682 (relative sequence number)]
  Acknowledgment Number: 1661 (relative ack number)
  Acknowledgment number (raw): 3452755585
  0101 .... = Header Length: 20 bytes (5)
  Flags: 0x018 (PSH, ACK)
  Window: 4100
  [Calculated window size: 1049600]
  [Window size scaling factor: 256]
  Checksum: 0x9523 [unverified]
  [Checksum Status: Unverified]
  Urgent Pointer: 0
  [Timestamps]
  [SEQ/ACK analysis]
  [Client Contiguous Streams: 1]
  [Server Contiguous Streams: 1]
  TCP payload (221 bytes)
  [PDU Size: 1681]
  TCP segment data (221 bytes)
[2 Reassembled TCP Segments (1681 bytes): #234(1460), #235(221)]
Kerberos
  Record Mark: 1677 bytes
  tgs-rep
    pvno: 5
    msg-type: krb-tgs-rep (13)
    crealm: NEMOTODES.HEALTH
    cname
      name-type: KRB5-NT-PRINCIPAL (1)
      cname-string: 1 item
      CNameString: oboomwald
    ticket
    enc-part
[Response to: 232]
[Time from request: 2.529000 milliseconds]
Missing keytype 18 usage 8 or 9 missing in frame 235 keytype 18 (id=missing.1 same=0) (000000)
```

SAMR-запросы: Перечисление пользователей и групп

329	17.131982	10.11.26.3	10.11.26.183	DCERPC	254 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 4280 max_recv: 4280, 3 results: Provider rejection, Acceptance, Negotiate ACK
330	17.132091	10.11.26.183	10.11.26.3	SAMR	318 connect5 request
331	17.132184	10.11.26.183	10.11.26.3	EPH	222 Map request, RPC_NETLOGON, 32bit NDR
332	17.132422	10.11.26.3	10.11.26.183	EPH	418 Map response, RPC_NETLOGON, 32bit NDR, RPC_NETLOGON, 32bit NDR, RPC_NETLOGON, 32bit NDR
333	17.132460	10.11.26.3	10.11.26.183	SAMR	234 connect5 response
334	17.132625	10.11.26.183	10.11.26.3	SAMR	230 EnumDomains request
335	17.132732	10.11.26.183	10.11.26.3	TCP	66 53295 - 49693 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
336	17.132896	10.11.26.3	10.11.26.183	TCP	66 49693 - 53295 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
337	17.132896	10.11.26.3	10.11.26.183	SAMR	378 EnumDomains response
338	17.132896	10.11.26.183	10.11.26.3	TCP	60 53295 - 49693 [ACK] Seq=1 Ack=1 Win=1049600 Len=0
339	17.132966	10.11.26.183	10.11.26.3	DCERPC	291 Bind: call_id: 2, Fragment: Single, 3 context items: RPC_NETLOGON V1.0 (32bit NDR), RPC_NETLOGON V1.0 (64bit NDR), RPC_NETLOGON
340	17.133054	10.11.26.183	10.11.26.3	SAMR	284 LookupDomain request
341	17.133114	10.11.26.3	10.11.26.183	DCERPC	182 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 5840 max_recv: 5840, 3 results: Provider rejection, Acceptance, Negotiate ACK
342	17.133315	10.11.26.3	10.11.26.183	SAMR	238 LookupDomain response
343	17.133449	10.11.26.183	10.11.26.3	RPC_NE	1078 NetLogonGetDomainInfo request
344	17.133544	10.11.26.183	10.11.26.3	SAMR	250 OpenDomain request
345	17.133829	10.11.26.3	10.11.26.183	SAMR	218 OpenDomain response
346	17.133973	10.11.26.183	10.11.26.3	SAMR	240 OpenDomain request
347	17.134283	10.11.26.3	10.11.26.183	RPC_NE	1086 NetLogonGetDomainInfo response
348	17.134367	10.11.26.3	10.11.26.183	SAMR	218 OpenDomain response
349	17.134520	10.11.26.183	10.11.26.3	SAMR	308 LookupNames request
350	17.134796	10.11.26.3	10.11.26.183	SAMR	258 LookupNames response
351	17.134939	10.11.26.183	10.11.26.3	SAMR	230 OpenUser request
352	17.135371	10.11.26.3	10.11.26.183	SAMR	218 OpenUser response
353	17.135519	10.11.26.183	10.11.26.3	SAMR	226 QueryUserInfo request
354	17.135846	10.11.26.183	10.11.26.3	TCP	60 53296 - 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
355	17.135951	10.11.26.3	10.11.26.183	SAMR	880 QueryUserInfo response
356	17.135951	10.11.26.3	10.11.26.183	TCP	66 389 - 53296 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
357	17.136071	10.11.26.183	10.11.26.3	TCP	60 53296 - 389 [ACK] Seq=1 Ack=1 Win=1049600 Len=0
358	17.136110	10.11.26.183	10.11.26.3	SAMR	220 QuerySecurity request
359	17.136236	10.11.26.183	10.11.26.3	LDAP	404 searchRequest(25) "(<ROOT>)" baseObject
360	17.136521	10.11.26.3	10.11.26.183	SAMR	418 QuerySecurity response
361	17.136602	10.11.26.183	10.11.26.3	SAMR	222 GetGroupsForUser request
362	17.136922	10.11.26.3	10.11.26.183	TCP	1514 389 - 53296 [ACK] Seq=1 Ack=351 Win=1049344 Len=1460 [TCP PDU reassembled in 363]
363	17.137035	10.11.26.3	10.11.26.183	LDAP	1393 searchResEntry(25) "(<ROOT>)" searchResDone(25) success [2 results]
364	17.137056	10.11.26.3	10.11.26.183	SAMR	230 GetGroupsForUser response
365	17.137081	10.11.26.183	10.11.26.3	TCP	60 53296 - 389 [ACK] Seq=351 Ack=2800 Win=1049600 Len=0
366	17.137216	10.11.26.183	10.11.26.3	SAMR	342 GetAliasMembership request

Этап 2

Подключение к \\NEMOTODES-DC\Shared_Files

428	17.376517	10.11.26.183	10.11.26.3	SMB2	723 Session Setup Request
429	17.376517	10.11.26.3	10.11.26.183	TCP	60 445 → 53298 [ACK] Seq=377 Ack=3201 Win=1049600 Len=0
430	17.378493	10.11.26.3	10.11.26.183	SMB2	315 Session Setup Response
431	17.378799	10.11.26.183	10.11.26.3	SMB2	184 Tree Connect Request, Tree: '\\NEMOTODES-DC\Shared_Files'
432	17.379106	10.11.26.3	10.11.26.183	SMB2	138 Tree Connect Response, Tree: '\\NEMOTODES-DC\Shared_Files'
433	17.379226	10.11.26.183	10.11.26.3	SMB2	178 Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
434	17.379419	10.11.26.3	10.11.26.183	SMB2	322 Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO

Поиск файлов Desktop.ini, AutoRun.inf

662	19.338636	10.11.26.183	10.11.26.3	SMB2	382 Create Request, File: Desktop.ini
663	19.338849	10.11.26.183	10.11.26.3	SMB2	234 Create Request, File: <share>
664	19.338979	10.11.26.3	10.11.26.183	TCP	60 445 → 53298 [ACK] Seq=990 Ack=4632 Win=1048064 Len=0
665	19.339376	10.11.26.3	10.11.26.183	SMB2	298 Create Response, File: <share>
666	19.339396	10.11.26.3	10.11.26.183	SMB2	130 Create Response, Error: STATUS_OBJECT_NAME_NOT_FOUND
667	19.339457	10.11.26.183	10.11.26.3	TCP	60 53298 → 445 [ACK] Seq=4632 Ack=1310 Win=1048320 Len=0
668	19.339592	10.11.26.183	10.11.26.3	SMB2	146 Close Request, File: <share>
669	19.339825	10.11.26.3	10.11.26.183	SMB2	182 Close Response, File: <share>
670	19.340796	10.11.26.183	10.11.26.3	SMB2	250 Create Request, File: AutoRun.inf
671	19.341123	10.11.26.3	10.11.26.183	SMB2	130 Create Response, Error: STATUS_OBJECT_NAME_NOT_FOUND

Анализ сетевых ресурсов через NetBIOS

Network traffic capture showing NetBIOS traffic between 10.11.26.3 and 10.11.26.183. The capture shows various NetBIOS messages including session setup, tree connect, and file creation requests. The traffic is filtered for NetBIOS (protocol 137) and shows a sequence of messages related to the connection to \\NEMOTODES-DC\Shared_Files. The capture also shows a large amount of traffic from 10.11.26.3 to 10.11.26.183, which is likely the data transfer for the files Desktop.ini and AutoRun.inf.

Этап 3

Далее похоже, что происходила эксфильтрация данных. И передача огромного количества пакетов данных. (Указаны примерные фреймы)

Фрейм 1184: 10.11.26.183 → 213.246.109.5 TCP 53322 → 443 [SYN] - установление основного канала

Фреймы 3935-3938: Одновременное создание 4 дополнительных TLS-соединений к 193.42.38.139

Фреймы 4715-4737: Массовые TCP Dup ACK и Fast Retransmission - признаки большого объема передачи

Фреймы 1228-1234: Активная передача TLS Application Data на внешние серверы

Этап 4

C2-коммуникация и запросы получения данных из базы через post запросы.

Регулярные HTTP POST запросы к fakeurl.htm: Фреймы 21337, 21352, 21364:

21333	484.761248	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21334	484.761339	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 11.26.1 is at 00:17:e0:b8:29:5e
21335	424.757760	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21336	424.757863	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21337	429.688226	10.11.26.183	194.180.191.64	HTTP	288 POST http://194.180.191.64/fakeurl.htm HTTP/1.1 (application/x-www-form-urlencoded)
21338	429.688912	194.180.191.64	10.11.26.183	TCP	60 443 - 53362 [ACK] Seq=522 Ack=2029 Win=131072 Len=0
21339	434.174793	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 Who has 10.11.26.183 Tell 10.11.26.1
21340	434.175083	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 10.11.26.183 is at 00:57:70:ce:fc:8b
21341	445.764445	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21342	445.764562	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21343	446.973611	10.11.26.3	10.11.26.183	TCP	60 [TCP Keep-Alive] 445 - 53298 [ACK] Seq=4461 Ack=7276 Win=1048576 Len=1
21344	446.973922	10.11.26.183	10.11.26.3	TCP	66 [TCP Keep-Alive] ACK] 53298 - 445 [ACK] Seq=7276 Ack=4462 Win=1048576 Len=0 SLE=4461 SRE=4462
21345	451.565072	52.113.194.132	10.11.26.183	TCP	60 443 - 53460 [RST, ACK] Seq=7403 Ack=2214 Win=0 Len=0
21346	451.760778	Intel_cfe:fb	Dell_7f:09:5d	ARP	60 Who has 10.11.26.37 Tell 10.11.26.183
21347	451.760890	Dell_7f:09:5d	Intel_cfe:fb	ARP	60 10.11.26.3 is at 00:24:e0:7f:09:5d
21348	466.756045	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21349	466.756152	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21350	486.755296	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21351	486.755322	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21352	489.150466	10.11.26.183	194.180.191.64	HTTP	288 POST http://194.180.191.64/fakeurl.htm HTTP/1.1 (application/x-www-form-urlencoded)
21353	489.424652	194.180.191.64	10.11.26.183	TCP	60 443 - 53362 [ACK] Seq=522 Ack=2863 Win=130816 Len=0
21354	494.167338	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.183 Tell 10.11.26.1
21355	494.167626	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 10.11.26.183 is at 00:57:70:ce:fc:8b
21356	507.764037	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21357	507.764749	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21358	514.479360	10.11.26.183	20.7.2.107	TCP	60 [TCP Keep-Alive] 53284 - 443 [ACK] Seq=2974 Ack=5801 Win=131072 Len=1
21359	514.564655	20.7.2.107	10.11.26.183	TCP	66 [TCP Keep-Alive] ACK] 443 - 53284 [ACK] Seq=5801 Ack=2975 Win=7274 Len=0 SLE=2974 SRE=2975
21360	527.760584	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21361	527.760618	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21362	549.253353	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 Who has 10.11.26.17 Tell 10.11.26.183
21363	549.253429	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 10.11.26.1 is at 00:17:e0:b8:29:5e
21364	549.264094	10.11.26.183	194.180.191.64	HTTP	288 POST http://194.180.191.64/fakeurl.htm HTTP/1.1 (application/x-www-form-urlencoded)
21365	549.583624	194.180.191.64	10.11.26.183	TCP	60 443 - 53362 [ACK] Seq=522 Ack=3097 Win=132096 Len=0
21366	554.176153	Cisco_b8:29:5e	Intel_cfe:fb	ARP	60 Who has 10.11.26.183 Tell 10.11.26.1
21367	554.176444	Intel_cfe:fb	Cisco_b8:29:5e	ARP	60 10.11.26.183 is at 00:57:70:ce:fc:8b
21368	566.978264	10.11.26.3	10.11.26.183	TCP	60 [TCP Keep-Alive] 445 - 53298 [ACK] Seq=4461 Ack=7276 Win=1048576 Len=1
21369	566.978567	10.11.26.183	10.11.26.3	TCP	66 [TCP Keep-Alive] ACK] 53298 - 445 [ACK] Seq=7276 Ack=4462 Win=1048576 Len=0 SLE=4461 SRE=4462

NetSupport Manager протокол:

Аномалии: HTTP трафик на порту 443, похоже на обмен данными User-Agent: NetSupport Manager/1.3. Также есть предположение что данный base64 это Kerberos authenticator.

После некоторых таких запросов начиналось скачивание файлов.

12789	62.427125	104.117.247.99	10.11.26.183	TCP	60 89 - 53361 [ACK] Seq=1 Ack=241 Win=64128 Len=0
12790	62.470288	104.117.247.99	10.11.26.183	OCSP	944 Response
12791	62.475595	10.11.26.183	193.42.38.139	TLSv1.3	478 Application Data
12792	62.475551	10.11.26.183	193.42.38.139	TLSv1.3	81 Application Data
12793	62.520590	10.11.26.183	104.117.247.99	TCP	60 53361 - 80 [ACK] Seq=241 Ack=891 Win=130384 Len=0
12794	62.597470	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [ACK] Seq=3289 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12802]
12795	62.597708	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [PSH, ACK] Seq=4055 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12802]
12796	62.597708	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=4055 Win=262144 Len=0
12797	62.597831	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [ACK] Seq=6041 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12802]
12798	62.597831	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=6041 Win=260608 Len=0
12799	62.597954	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [PSH, ACK] Seq=7417 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12802]
12800	62.598071	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [ACK] Seq=8793 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12802]
12801	62.598071	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=7417 Win=262144 Len=0
12802	62.598194	193.42.38.139	10.11.26.183	TLSv1.3	1430 Application Data
12803	62.598194	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=8793 Win=260608 Len=0
12804	62.598217	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=10169 Win=262144 Len=0
12805	62.598338	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [ACK] Seq=818 Ack=11545 Win=260608 Len=0
12806	62.598528	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [ACK] Seq=11545 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12823]
12807	62.598575	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [PSH, ACK] Seq=12921 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12823]
12808	62.598618	193.42.38.139	10.11.26.183	TCP	1430 443 - 53360 [ACK] Seq=14947 Ack=818 Win=64128 Len=1376 [TCP PDU reassembled in 12823]

1330	35.683440	10.11.26.183	213.246.109.5	TLSv1.3	175 Application Data
1331	35.683460	10.11.26.183	213.246.109.5	TLSv1.3	206 Application Data
1332	35.687316	10.11.26.183	10.11.26.3	DNS	80 Standard query 0xa31d A modandcrackedapk.com
1333	35.687396	10.11.26.183	10.11.26.3	DNS	80 Standard query 0x58e5 HTTPS modandcrackedapk.com
1334	35.692323	10.11.26.183	10.11.26.3	DNS	83 Standard query 0x4e4d A confirmsubscription.com
1335	35.692433	10.11.26.183	10.11.26.3	DNS	83 Standard query 0x5656 HTTPS confirmsubscription.com
1336	35.778515	10.11.26.3	10.11.26.183	TCP	139 Standard query response 0x5656 HTTPS confirmsubscription.com SOA ns0.dnsmadeeasy.com
1337	35.778278	10.11.26.3	10.11.26.183	DNS	115 Standard query response 0x4e4d A confirmsubscription.com A 52.8.34.0 A 13.56.30.207
1338	35.778756	10.11.26.183	52.8.34.0	TCP	66 53325 - 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
1339	35.815061	213.246.109.5	10.11.26.183	TCP	60 443 - 53322 [ACK] Seq=24203 Ack=2699 Win=40576 Len=0

Этап 5

По завершении всего были выполнены запросы к базе данных SMB с просмотром и поиском данных. Некоторые попытки этих запросов были еще в самом начале дампа.

26662	3019.555327	10.11.26.3	10.11.26.183	TCP	60 445 - 53497 [ACK] Seq=629 Ack=3400 Win=1049600 Len=0
26663	3019.556268	10.11.26.3	10.11.26.183	SMB2	315 Session Setup Response
26664	3019.556726	10.11.26.3	10.11.26.183	SMB2	206 Tree Connect Request, Tree: '\\NEMOTODES-DC.nemotodes.health\sysvol'
26665	3019.557118	10.11.26.3	10.11.26.183	SMB2	138 Tree Connect Response, Tree: '\\NEMOTODES-DC.nemotodes.health\sysvol'
26666	3019.557558	10.11.26.183	10.11.26.3	SMB2	178 Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
26667	3019.557694	10.11.26.3	10.11.26.183	SMB2	322 Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
26668	3019.557705	10.11.26.183	10.11.26.3	SMB2	502 Create Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26669	3019.558044	10.11.26.3	10.11.26.183	SMB2	410 Create Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26670	3019.558288	10.11.26.183	10.11.26.3	TCP	60 53497 - 445 [ACK] Seq=5829 Ack=1598 Win=131328 Len=0
26671	3019.558407	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26672	3019.558570	10.11.26.3	10.11.26.183	SMB2	196 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26673	3019.558879	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26674	3019.558976	10.11.26.3	10.11.26.183	SMB2	186 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26675	3019.559366	10.11.26.183	10.11.26.3	SMB2	171 Read Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26676	3019.559494	10.11.26.3	10.11.26.183	SMB2	160 Read Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26677	3019.563779	10.11.26.183	10.11.26.3	SMB2	445 Create Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26678	3019.564264	10.11.26.3	10.11.26.183	SMB2	378 Create Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26679	3019.564587	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26680	3019.564692	10.11.26.3	10.11.26.183	SMB2	186 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26681	3019.564899	10.11.26.183	10.11.26.3	SMB2	260 Find Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26682	3019.565145	10.11.26.3	10.11.26.183	SMB2	602 Find Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26683	3019.565683	10.11.26.183	10.11.26.3	SMB2	470 Create Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26684	3019.566145	10.11.26.3	10.11.26.183	SMB2	378 Create Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26685	3019.566380	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26686	3019.566490	10.11.26.3	10.11.26.183	SMB2	186 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26687	3019.566653	10.11.26.183	10.11.26.3	SMB2	260 Find Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26688	3019.566870	10.11.26.3	10.11.26.183	SMB2	554 Find Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26689	3019.567562	10.11.26.183	10.11.26.3	SMB2	494 Create Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26690	3019.568033	10.11.26.3	10.11.26.183	SMB2	378 Create Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26691	3019.568301	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26692	3019.568402	10.11.26.3	10.11.26.183	SMB2	186 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26693	3019.568576	10.11.26.183	10.11.26.3	SMB2	260 Find Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26694	3019.568813	10.11.26.3	10.11.26.183	SMB2	546 Find Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26695	3019.569566	10.11.26.183	10.11.26.3	SMB2	510 Create Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26696	3019.570832	10.11.26.3	10.11.26.183	SMB2	378 Create Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26697	3019.572621	10.11.26.183	10.11.26.3	SMB2	162 GetInfo Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26698	3019.573862	10.11.26.3	10.11.26.183	SMB2	186 GetInfo Response, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini
26699	3019.575937	10.11.26.183	10.11.26.3	SMB2	260 Find Request, File: nemotodes.health\Policies\{31B2F340-0160-11D2-945F-00C04F8984F9}\vpt.ini

Дополнительно

Совершались работы с некоторыми доменами (см. вкладка подозрительные домены) и выполнение запросов на информацию об пользователе.

```
21265 318.581635 10.11.26.183 10.11.26.3 LDAP 218 SASL GSS-API Integrity:
searchRequest(4) "CN=Oliver Q.. Boomwald,CN=Users,DC=nemotodes,DC=health" baseObject
21266 318.582512 10.11.26.3 10.11.26.183 LDAP 242 SASL GSS-API Integrity:
searchResEntry(4) "CN=Oliver Q.. Boomwald,CN=Users,DC=nemotodes,DC=health"
searchResDone(4) success [2 results]
```

Происходило скачивание ProcessMAU.txt, а прямо перед его скачивание есть Isa_Lookup_Names4 request.

Данные, к которым получил доступ злоумышленник (возможно были украдены)

1. Доменная информация и учетные данные, а именно SAMR-запросы (EnumDomains, QueryUserInfo, GetGroupsForUser) и LDAP-поиск структуры домена, сайтов и групповых политик.
2. Получен доступ к \\NEMOTODES-DC\Shared_Files
3. Массовая эксфильтрация через TLS-каналы. Конкретно непрерывная передача TLS Application Data на внешние серверы. А также TCP Dup ACK, Fast Retransmission, TCP Spurious Retransmission - признаки передачи огромного объема информации.
4. Поиск WPAD-прокси (wpad.nemotoads.health, wpad.mshome.net) и его возможное получение.
5. Доступ к файлам групповых политик в \\NEMOTODES-DC\sysvol
6. Возможно, геолокационная информация (location.locas.asp)
7. Файлы (gpt.ini, GptTmpl.inf, Registry.pol)
8. Информация о сетевых интерфейсах через FSCTL_QUERY_NETWORK_INTERFACE_INFO

Сетевые индикаторы компрометации

1. 194.180.191.64:443 - HTTP C2 бэкдор (фреймы 21337, 21352, 21364).
Предположительно основной ip злоумышленника.
2. 213.246.109.5:443
3. 193.42.38.139:443
4. 173.222.49.101:443
5. 18.160.156.61:443 - CDN-инфраструктура

Подозрительные домены

1. modandcrackedapk.com 193.42.38.139 (фреймы около 2500 фрейма)
2. classicgrand.com 213.246.109.5 (фреймы около 1100 фрейма)
3. confirmsubscription.com 13.56.30.207 (фреймы около 2700 фрейма)
4. createsend1.com 18.160.156.0/24 (фреймы около 2600 фрейма)

Поведенческие индикаторы компрометации

Аномальная активность подтверждена фреймами (указаны примерные фреймы):

- Фреймы 330-381: Массовые SAMR/LDAP-запросы с рабочей станции к доменному контроллеру
- Фреймы 4715-4737: TCP сетевые аномалии (Dup ACK, Fast Retransmission) из-за объемов передачи
- Периодические HTTP POST и GET запросы
- Фреймы 3935-3938: Множественные одновременные TLS-сессии к одним IP-адресам

Скомпрометированные объекты

- Учетная запись: oboomwald (Oliver Q. Boomwald)
- Рабочая станция: DESKTOP-B8TQK49 (10.11.26.183)
- Доменный контроллер: NEMOTODES-DC (10.11.26.3)
-

Технические индикаторы, протоколы и аномалии

- User-Agent: NetSupport Manager/1.3 - HTTP POST запросов
- HTTP на порту 443 - аномалия протокола
- C2-протокол: CMD=POLL\nINFO=1\nACK=1\n - формат heartbeat-сообщений
- Геолокация:

Ссылка	Время	Адрес	Порт	Протокол	Содержимое
28329	67.176894	10.11.26.183	193.42.38.139	TCP	60 53360 - 443 [RST, ACK] Seq=1890 Ack=5287412 Win=0 Len=0
28329	67.176894	10.11.26.183	194.117.247.89	TCP	60 53361 - 80 [RST, ACK] Seq=241 Ack=891 Win=0 Len=0
28330	67.184244	10.11.26.183	194.180.191.64	TCP	66 53362 - 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
28331	67.188937	10.11.26.183	10.11.26.3	DNS	86 Standard query 0x0be4 A geo.netsupportsoftware.com
28332	67.220270	10.11.26.3	10.11.26.183	DNS	134 Standard query response 0x0be4 A geo.netsupportsoftware.com A 104.26.1.231 A 172.67.68.212
28333	67.229210	10.11.26.183	104.26.1.231	TCP	60 53363 - 80 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
28334	67.284755	104.26.1.231	10.11.26.183	TCP	66 80 - 53363 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1388 SACK_PERM WS=8192
28335	67.285917	10.11.26.183	104.26.1.231	TCP	60 53363 - 80 [ACK] Seq=1 Ack=1 Win=262144 Len=0
28336	67.286490	10.11.26.183	104.26.1.231	HTTP	172 GET /location/loca.asp HTTP/1.1